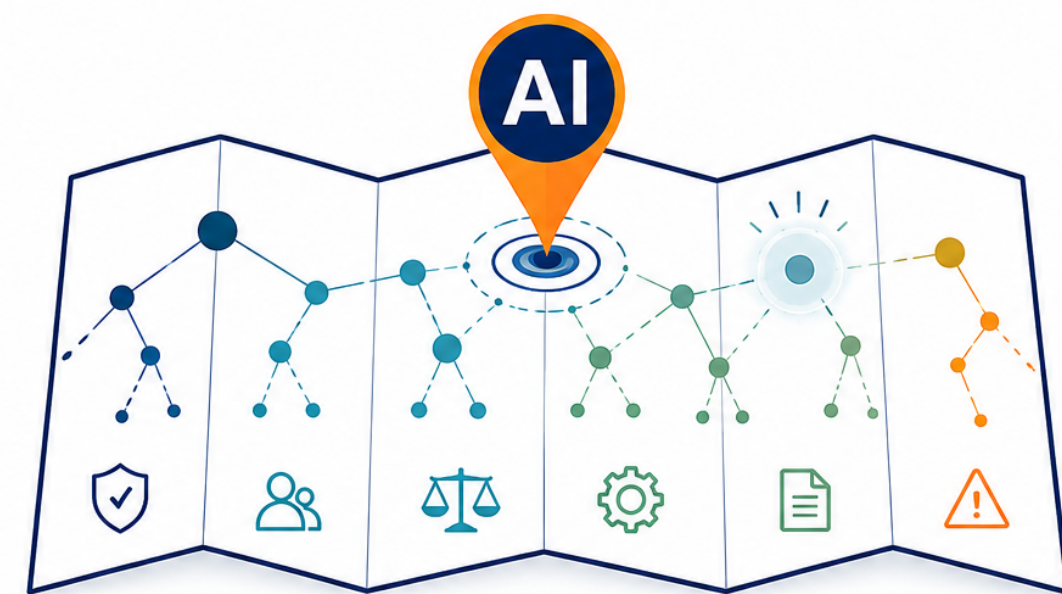


AI Risk Map

A thought-starter for identifying AI-specific risks.

For risk, security, legal, and business teams widening their view of their organization's AI adoption risk before formal assessment.



12 domains 54 categories 189 risk factors Organized by who owns the risk, not by how the technology works. HOW TO READ 1. Domain → Category → Risk factor »8 = other face of this risk, owned by domain 8

01 AI Governance & Accountability	02 Strategy & Value Realization	03 Data & Privacy	04 Model Development & Performance	05 Security & Adversarial Threats	06 Safety, Ethics & Responsible AI	07 Operations & Resilience	08 Legal, Regulatory & Compliance	09 Third-Party & Model Supply Chain	10 Workforce, Human & Societal	11 Financial & Resource	12 Autonomy & Delegated Action (Agentic AI)
Governance & oversight - Inadequate executive/board oversight of AI adoption and risk - Ungoverned 'shadow AI' adoption outside sanctioned channels - Absence of an AI governance body or charter with a clear mandate	AI strategy & roadmap - Lack of a coherent AI strategy aligned to objectives and risk appetite - AI adoption driven by hype rather than demonstrated business value »11 - Inability to adapt the roadmap as foundation-model capabilities shift	Sourcing & provenance - Unknown or undocumented provenance of training / grounding data - Reliance on data scraped without lawful basis or clear rights - Inadequate data lineage to trace data through the AI pipeline	Design & training - Inappropriate model/algorithm choice for the problem and risk context - Poorly documented or untracked model development - Insecure or unmanaged hyperparameters and training configuration	Data & pipeline attacks - Training-data poisoning that degrades or backdoors model behavior - Tampering with RAG / knowledge-base sources consumed at inference - Label-flipping or adversarial dataset partitioning	Bias & fairness - Discriminatory or biased outputs causing disparate impact - Inequitable performance across languages, demographics, and disabilities - Bias amplification / homogenization from feedback and scale - Culturally inappropriate output as AI scales across regions	MLOps & deployment - Immature MLOps / fragile deployment pipelines - Inconsistent or unsanctioned (shadow) model deployment - Environment and config management gaps undermining reproducibility - Training-serving skew degrading live performance - Test or sandbox containment fails and AI reaches real systems	Regulatory compliance - Unknowingly deploying a prohibited or high-risk AI use case - Failure to meet high-risk obligations (risk mgmt, docs, oversight) - Inability to keep pace with fragmented, fast-changing AI regulation - User inability to contest or seek recourse on an AI-driven decision - Misclassified as deployer when fine-tuning makes you a provider	Foundation-model dependence - Concentration risk from dependence on a few model providers - Systemic / correlated 'model monoculture' — shared-model failure »11 - Model deprecation or behavior change forcing unplanned migration	Skills & talent - Shortage of AI and AI-risk talent, competing against AI-native employers for scarce skills - Inability to retain specialists, who leave taking undocumented model and prompt knowledge with them - Inadequate AI literacy across the workforce and leadership	Cost & compute economics - Runaway inference / training costs without FinOps discipline - Poor cost forecasting, because inference cost scales with usage rather than seats or provisioned capacity - Environmental / energy footprint of training and inference	Autonomy, alignment & oversight - Agent pursues unintended goals or misgeneralizes its objective - Agent pursues an authorized objective through unauthorized means - Excessive autonomy / agency beyond intended mandate - No human checkpoint or working interrupt / kill switch for an agent mid-task »6
Roles & accountability - Unclear ownership and accountability (RACI) for AI risk decisions - Diffusion of responsibility with no convention for who decides - Accountability for agent decisions undefined, internally and across the AI stack »7 »12 - Segregation of duties collapses across AI config, operation, and review	Use-case selection & sourcing - Selection of use cases without weighing incremental risk against benefit 'Pilot purgatory' — pilots stalling on data readiness, evaluation difficulty, or inability to demonstrate value - Misjudged AI sourcing fork: train, fine-tune, RAG, or API - Failure to weigh the competitive risk of not adopting AI (inaction)	Quality & labeling - Poor data quality undermining model reliability - Inadequate or biased labeling introducing systematic error - Stale data, including grounding and retrieval sources that drift out of date behind a confident-sounding model	Accuracy & validation - Fluent but factually incorrect output (hallucination) accepted as reliable »6 - Validation/evaluation data not representative of real-world use - Skipped or insufficient pre-deployment red-teaming / safety evaluation - Absence of independent model validation / effective challenge	Model attacks - Model extraction / theft via inference-API querying - Membership-inference or model-inversion exposing training data »3 - Backdoored / trojaned pre-trained model from a public hub	Harmful / inaccurate output - Generation of toxic, dangerous, or hateful content »5 - Harmful, misleading, or defamatory output driving decisions »4 - Harm to minors / vulnerable users from inappropriate output	Monitoring & observability - Absence of monitoring for performance, drift, and abuse in any environment »4 - Inadequate logging of inputs, outputs, tool calls, agent decisions, and who authorized them »1 - Non-determinism making anomalous behavior hard to define or detect - Sanctioned agent activity indistinguishable from agentic attack in telemetry	IP & liability - Liability for harm caused by AI decisions or outputs - Infringement claims arising from AI-generated output »3 - Uncertain ownership / copyrightability of AI-generated content	Vendor due diligence - Vendor diligence missing: are prompts retained, trained on, or shared? - No way to verify a vendor's 'AI-powered' claim before buying it - Vendor viability risk in an unusually volatile provider market with frequent pivots and deprecations - Regulator / customer holding the firm responsible for the vendor's AI	Deskilling & loss of institutional knowledge - Erosion of staff expertise through over-delegation to AI - Loss of institutional knowledge as AI replaces human processes - Capability atrophy — inability to operate if AI is unavailable	Investment / procurement - Stranded investment in failed or abandoned AI initiatives »2 - Procurement exposure where providers reprice tokens, tiers, or context windows unilaterally - Insurance excludes AI losses, or defines 'user' as human only	Tool access & authorization - Agent granted a broader set of invocable tools / functions than its task requires »5 - Agent identity misuse, impersonation, or delegated-credential abuse »5 - Third-party tool/connector servers as an unvetted execution surface
Policy & standards - Absence of an AI acceptable-use policy and model-approval gates - AI policies not kept current with evolving capabilities and regulation - Inconsistent standards as AI proliferates faster than governance - No agreed definition of 'AI', leaving policy and inventory scope undefined	Value measurement / ROI - Unrealistic ROI expectations, where AI benefits are diffuse and hard to attribute to the system itself - Inability to attribute value actually delivered by AI investments - Hidden total cost of ownership (data, talent, integration) eroding returns	Privacy & consent - Personal data used for training without consent or purpose limitation »5 - Inability to honor data-subject rights once data is in a model - Re-identification of individuals from aggregated or model-derived data - Inadvertent disclosure of confidential / personal data in model output (no output guardrails) - Unclassified sensitive data in AI, so handling controls never apply - Confidential data pasted into an approved AI tool, leaving despite working controls	Robustness & drift - Model drift degrading performance as data / conditions change »7 - Lack of robustness to edge cases and distribution shift - Small changes to the input produce very different output	Inference-time (input) attacks - Direct prompt injection altering behavior or bypassing guardrails - Indirect / cross-domain prompt injection via retrieved content - Jailbreaks defeating safety controls and restrictions »6 - System-prompt leakage exposing operational instructions	Transparency, disclosure & provenance - Failure to disclose to users that they are interacting with AI »1 - Undisclosed synthetic media / deepfakes lacking provenance - Inadequate transparency to affected parties about AI's role	Availability & scalability - Inference latency or unavailability degrading dependent services »11 - Inability to scale inference to peak demand - Unbounded resource consumption / denial-of-wallet from AI workloads	Contractual & licensing - Vendor contracts lacking AI terms: training use, output ownership, change notice - Violation of open-weight / model license terms - Failure to update contracts as AI use and regulation evolve	Lock-in & portability - Vendor / model lock-in limiting portability and leverage - High switching cost from proprietary APIs and fine-tuning - Lack of exit provisions, where fine-tunes, embeddings, and prompt assets do not transfer between providers	Workforce disruption / change - Change management underestimated as AI reshapes the work itself - Workforce resistance or low adoption driven by displacement fear or distrust of AI output - Labor-relations and morale impacts of AI deployment	Scaling & resource constraints - Compute / GPU scarcity constraining scaling »7 - Cost non-linearity as usage scales to production volume - Concentration of compute supply among few providers »9	Memory & context integrity - Memory poisoning corrupting agent state across sessions - Context-window manipulation altering agent behavior - Persistence of corrupted or sensitive data in agent memory
Risk-management integration - AI risk not integrated into enterprise risk management (ERM) - Failure to conduct AI impact assessments for individuals and society - No defined risk appetite or tolerance thresholds for AI		Training-data rights & IP - Use of copyrighted or licensed material in training without rights »8 - Contamination of datasets with third-party IP or trade secrets - Inability to prove you held rights to the training data used	Explainability - Black-box models used in high-stakes decisions without interpretability - Inability to produce adverse-action / decision explanations - Over-reliance on post-hoc explanations that misrepresents the model	Output & integration security - Unsanitized output reaching downstream interpreters - Interception or manipulation of the inference output stream - Over-trusted output triggering unsafe automated actions	Misuse & dual-use - Misuse of AI for disinformation, fraud, or social engineering - Model gives meaningful help toward weapons or cyberattack capability - Engagement-optimized AI driving addiction, polarization, or harm	Incident management - Immature AI incident response and escalation processes - Inability to investigate AI incidents due to non-determinism / poor logs - Inadequate content-moderation / trust-&-safety operations at scale - Defensive model refuses to analyze attack data mid-incident	Cross-border - Cross-jurisdictional data-transfer violations, including inference requests routed across borders invisibly by the provider - Conflicting regional AI requirements the organization cannot reconcile for a single system (externally imposed) - Inability to evidence and audit AI compliance across jurisdictions (internal evidence burden)	Open-source component risk - Malicious or compromised open-source models / components - Unmaintained or vulnerable open-source AI dependencies - Opaque sub-processor chains, including models served behind a vendor's own API without disclosure - Model's true lineage hidden behind its publisher label, so upstream flaws can't be traced »5	Societal & reputational - Reputational damage from a visible AI failure or misuse - Erosion of customer / stakeholder trust in AI-mediated services - Harm to decision subjects and bystanders who never chose to use the system - AI-washing: overstating capability to customers, investors, or regulators		Multi-agent orchestration - Cascading failures or loops across interacting agents - Misplaced inter-agent trust or agent collusion - Emergent, unpredictable behavior in multi-agent systems
Audit & assurance - Inability to audit AI: no complete inventory of models, agents, and connectors »4 »6 - Insufficient internal-audit competence to assess AI controls - Absence of independent assurance over AI control effectiveness - AI output relied on in financial-reporting controls without scope change - No way to identify which artifacts AI produced, so a model flaw cannot be scoped		Retention & disposal - Failure to preserve prompts, outputs, and agent traces subject to litigation hold or e-discovery - Deletion at source does not remove data absorbed into models - Persistence of sensitive data in embeddings, caches, or model weights - Failure to remove data across distributed / replicated AI stores	Reproducibility & documentation - Non-reproducible training pipelines undermining validation and audit - Inadequate model documentation / model cards »1 - Loss of traceability between model versions, data, and results	Supply-chain & artifact integrity - Compromised or malicious model from the AI supply chain »9 - Vulnerable or unmaintained ML dependencies and libraries - Tampering with model artifacts in registries or during deployment - Model-invented dependencies resolving to adversary-registered packages	Human agency & over-reliance - User over-trust / automation bias in AI outputs - Anthropomorphism and emotional dependence on conversational AI - Erosion of meaningful human control over decisions »12 - Review capacity cannot scale to AI output volume, degrading oversight to rubber-stamping	Change & lifecycle management - Silent vendor / model updates changing behavior without notice - Inadequate versioning, rollback, and change control for models - Unmanaged model decommissioning / sunset leaving orphaned dependencies - Uncontrolled continuous / online learning introducing drift or poisoning - Controls re-verified less often than the AI system changes - Prompts and retrieval config changed outside change control				Action integrity & traceability - Unsafe or irreversible real-world action taken by an agent - Accountability gap for harm caused by autonomous action »1	

How to use this map

1. Form — each entry is a risk FACTOR: a condition, failure mode, or event that contributes to risk. Scope it before analysis.

2. Quantification — some factors scope cleanly into CROQ/FAIR scenarios; others are board-narrative.

3. Likelihood — position and size do not imply likelihood or severity; rare high-impact factors sit beside common ones.

4. Use — this map seeds threat modeling and risk assessment; it complements, it does not replace, system-specific models.

5. Scope — risks from your organization's adoption of AI; others' use of AI against you belongs on your threat register. Not exhaustive; customize to your context.

Sources: NIST AI RMF & GenAI Profile · EU AI Act · ISO/IEC 42001 · OWASP LLM & Agentic Top 10 · OWASP AISVS 1.0 · MITRE ATLAS · Databricks DASf v3.0 · Databricks AI Governance Framework · COSO Internal Control over GenAI (2026) · CRI FS-AI-RMF v1.0 · CSA AICM v1.1 · MIT AI Risk Repository · Intl AI Safety Report · Weidinger/Shelby taxonomies · Colorado AI laws · SR 11-7 · Databricks DASf and AI Governance Framework are © Databricks, licensed CC BY-SA 4.0. Full risk-to-source provenance in the companion workbook.